5. Standarde de Securitate

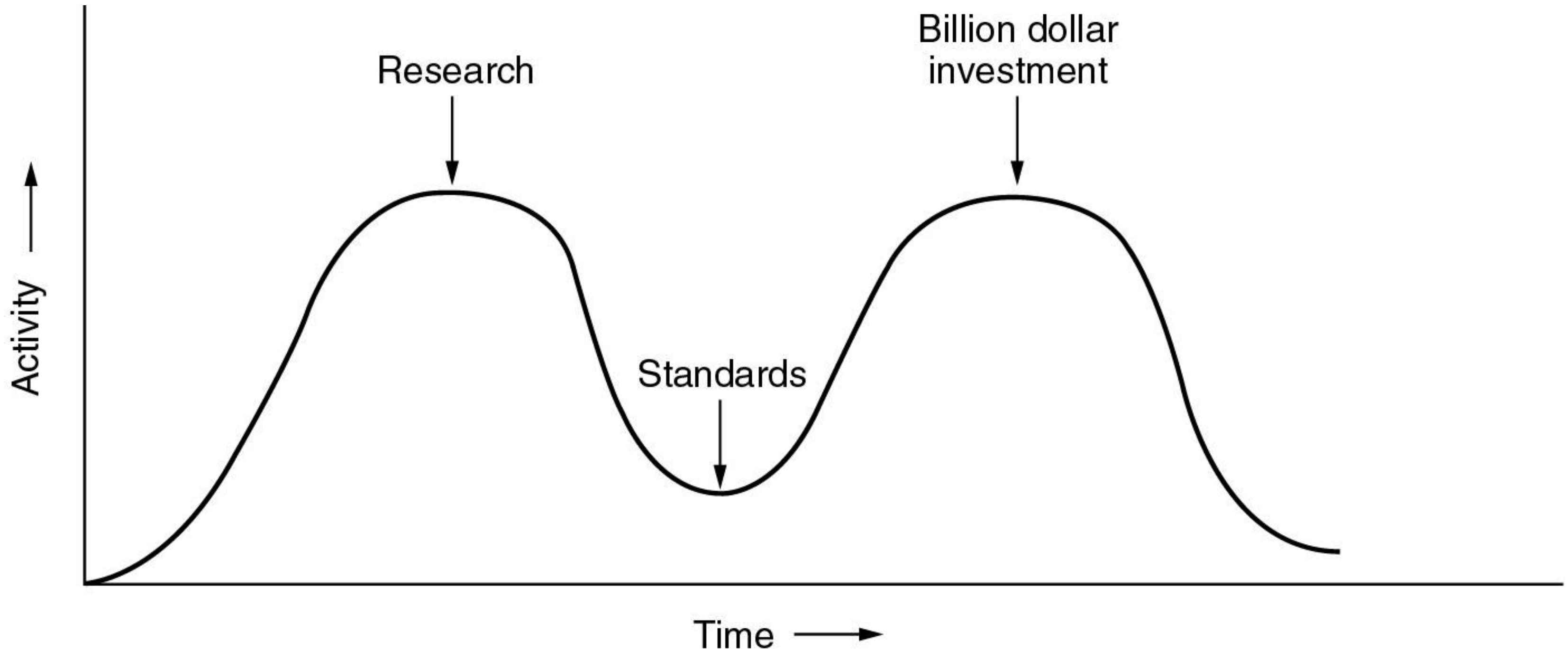
Standard de securitate

- **Rolul standardelor:**
  - **asigurarea interoperabilităţii**
- **Tipuri de standarde**
  - ***de jure*** **(FIPS, ANSI, etc.)**
  - ***de facto*** **(PKCS, etc.)**

"The nice things about standards is that you have so many to choose from"

Andrew Tanenbaum

Standarde de securitate (cont.)



Apocalipsa celor doi elefanţi

(David Clark, MIT)

Organizaţii de standardizare

- Internet Society
  - Internet Architecture Board (IAB)
  - Internet Engineering Task Force (IETF)
  - Internet Engineering Steering Group (IESG)
  - Draft -> Request for Comment (RFC) -> Standard
- International Telecommunication Union (ITU)
  - ITU-R (Radiocommunications Sector)
  - ITU-T (Telecommunications Sector) - CCITT
  - ITU-D (Development Sector)
- Institute of Electrical and Electronics Engineers (IEEE)
- European Telecommunications Standards Institute (ETSI)
- European Committee for Standardization (CEN)
- International Standards Organization (ISO)
- National Standards Organization
  - ANSI (US), BSI (GB), AFNOR (FR), DIN (GE), etc.

Organizaţii de standardizare (cont.)

- National Institute of Standards and Technology (NIST)
- RSA Laboratories
  - Public Key Cryptography Standards
- World Wide Web Consortium (W3C)
  - XML Signature WG
  - XML Encryption WG
  - XML Key Management WG
- The OpenGroup (IBM, HP, SUN, NEC, Fujitsu)
  - Common Data Security Architecture (CDSA)
- Organization for the Advancement of Structured Information Standards (OASIS)
  - Security Assertion Markup Language (SAML)
- PC/SC Workgroup (Gemplus, Axalto, Infineon)
  - Smart card
- EMV (Europay, Mastercard, VISA)
  - Carduri bancare

IETF – Grupuri de lucru active pe security

▪ ace	Authentication and Authorization for Constrained Environments
▪ acme	Automated Certificate Management Environment
▪ curdle	CURves, Deprecating and a Little more Encryption
▪ dots	DDoS Open Threat Signaling
▪ i2nsf	Interface to Network Security Functions
▪ ipsecme	IP Security Security Maintenance and Extensions
▪ kitten	Common Authentication Technology Next Generation
▪ lamps	Limited Additional Mechanisms for PKIX and SMIME
▪ mile	Managed Incident Lightweight Exchange
▪ oauth	Web Authorization Protocol
▪ sacm	Security Automation and Continuous Monitoring
▪ secevent	Security Events
▪ tls	Transport Layer Security
▪ tokbind	Token Binding
▪ trans	Public Notary Transparency

ITU

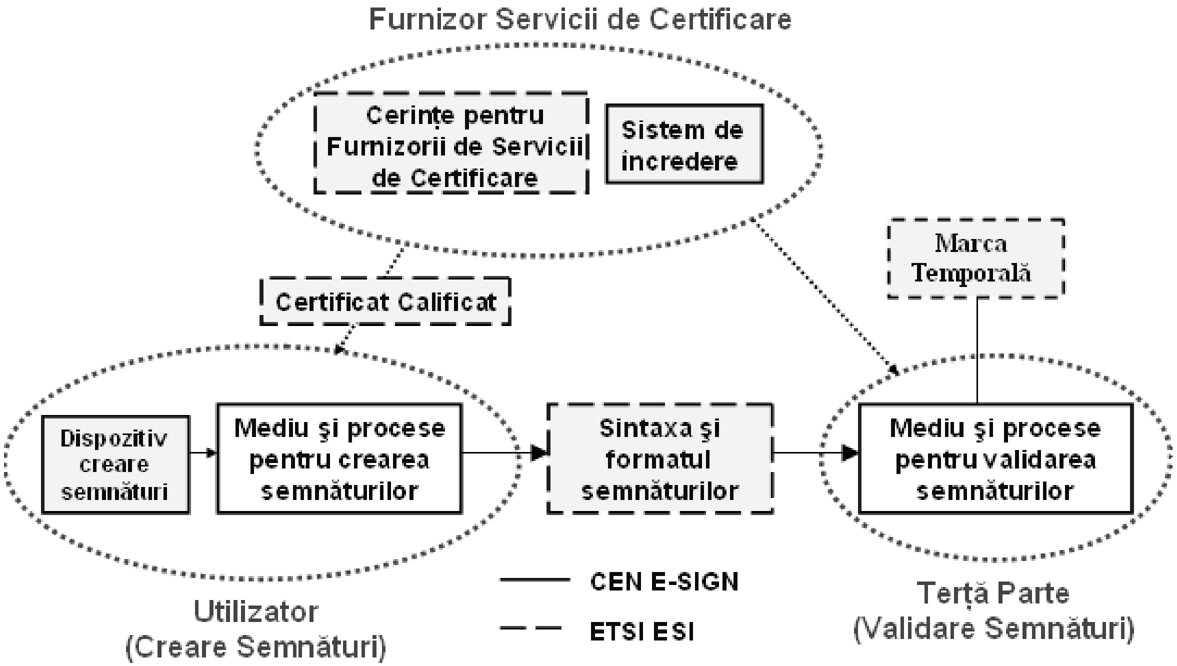
- [X.273] Recommendation X.273 - Information technology - Open Systems Interconnection - Network layer security protocol
- [X.274] Recommendation X.274 - Information technology - Telecommunication and information exchange between systems - transport layer security protocol
- [X.509] Recommendation X.509 - Information technology - Open Systems Interconnection - The directory: Authentication framework
- [X.736] Recommendation X.736 - Information technology - Open Systems Interconnection - Systems management: Security alarm reporting function
- [X.736 SUMMARY] Summary of Recommendation X.736 - Information technology - open systems interconnection - systems management: security alarm reporting function
- [X.740] Recommendation X.740 - Information technology - Open Systems Interconnection - systems management: security audit trail function
- [X.800] Recommendation X.800 - Security architecture for Open Systems Interconnection for CCITT applications
- [X.800 SUMMARY] Summary of Recommendation X.800 - Security architecture for open systems interconnection for CCITT applications
- [X.802] Recommendation X.802 - Information technology - Lower layers security model
- [X.803] Recommendation X.803 - Information Technology - Open Systems Interconnection - Upper layers security model

IEEE

- Standard Specifications for Public-Key Cryptography (P1363)
- IEEE 802.1x: Standard for port-based Network Access Control (PNAC)
- IEEE 802.11i: Standard for Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) specifications - Amendment 6: Medium Access Control (MAC) Security Enhancements

EESSI

- **European Electronic Signature Standardization Initiative**
  - **Standardizarea semnăturilor electronice**
- **ETSI ESI**
- **CEN/ISSS**



ETSI ESI

- peste 50 de standarde

- TS 101 862 Qualified Certificate Profile
- TS 101 733 Electronic Signature Formats
- TS 101 903 XML Advanced Electronic Signatures (XAdES)
- TS 101 456 Policy requirements for Certification Authorities issuing Qualified Certificates
- SR 002 176 Algorithms and Parameters for Secure Electronic Signatures
- TS 101 861 Time stamping profile
- TS 102 023 Policy requirements for time-stamping authorities
- TR 102 272 ASN.1 format for signature policies
- ...

CEN/ISSS

- peste 20 de standarde

- CWA 14167 Security Requirements for Trustworthy Systems Managing Certificates for Electronic Signatures (Part 1,2,3,4)
- CWA 14169 Secure Signature-creation devices "EAL 4+"
- CWA 14170 Security requirements for signature creation applications
- CWA 14171 General guidelines for electronic signature verification
- CWA 14172 EESSI Conformity Assessment Guidance (Part 1,2,3,4,5,6,7,8)
- CWA 14355 Guidelines for the implementation of Secure Signature-Creation Devices
- CWA 14365 Guide on the Use of Electronic Signatures (Part 1,2)
- CWA 14890 Application Interface for smart cards used as Secure Signature Creation Devices (Part 1,2)
- …

ISO

- ISO/IEC Frameworks:
  - ISO/IEC 7498-2: Open Systems Interconnect (OSI) Security Model
  - ISO/IEC 9797: Message Authentication Codes (MACs)
  - ISO/IEC 10181: Security Frameworks
  - ISO/IEC 10736: Transport Layer Security Protocol (TLSP)
  - ISO/IEC 11577: Network Layer Security Protocol (NLSP)
  - ISO/IEC 11770: Key Management
  - ISO/IEC 13888: Non-Repudiation
- ISO/IEC Cryptographic Mechanisms:
  - ISO/IEC 9796: Digital Signature Scheme giving Message Recovery
  - ISO/IEC 10116: Modes of Operation for an n-bit Block Cipher
  - ISO/IEC 10118: Hash Functions
  - ISO/IEC 14888: Digital Signatures with Appendix
  - ISO/IEC 15946: Information Technology - Security Techniques – Cryptographic techniques based on elliptic curves

ISO (cont.)

- ISO/IEC 27000 Series:
  - ISO/IEC 27000: Information security management systems - Overview and vocabulary
  - ISO/IEC 27001: Information technology - Security Techniques - Information security management systems - Requirements.
  - ISO/IEC 27002: Code of practice for information security management
  - ISO/IEC 27003: Information security management system implementation guidance
  - ISO/IEC 27004: Information security management - Monitoring, measurement, analysis and evaluation
  - ISO/IEC 27005: Information security risk management

ANSI

- ANSI X9.23: Data Encryption Standard
- ANSI X9.26: Secure Sign-On
- ANSI X9.30: Digital Signature Standard
- ANSI X9.31: RSA
- ANSI X9.41: Security Services Management
- ANSI X9.42: Diffie-Hellman Key Agreement
- ANSI X9.43: Key Archiving and Retrieval
- ANSI X9.57: Certificate Management
- ANSI X9.62: Elliptic Curve Digital Signature Algorithm

NIST

- FIPS Pub 46-2: Data Encryption Standard
- FIPS Pub 81: DES Modes of Operation
- FIPS Pub 112: Standard on Password Usage
- FIPS Pub 140: Security Requirements for Cryptographic Modules
- FIPS Pub 180: Secure Hash Standard
- FIPS Pub 185: Escrowed Encryption Standard
- FIPS Pub 186: Digital Signature Standard (DSS)
- FIPS Pub 197: Advanced Encryption Standard (AES)
- FIPS Pub 198: The Keyed-Hash Message Authentication Code (HMAC)

RSA Labs

- PKCS #1: RSA Cryptography Standard
- PKCS #3: Diffie-Hellman Key Agreement Standard
- PKCS #5: Password-Based Cryptography Standard
- PKCS #6: Extended-Certificate Syntax Standard
- PKCS #7: Cryptographic Message Syntax Standard
- PKCS #8: Private-Key Information Syntax Standard
- PKCS #9: Selected Attribute Types
- PKCS #10: Certification Request Syntax Standard
- PKCS #11: Cryptographic Token Interface Standard
- PKCS #12: Personal Information Exchange Syntax Standard
- PKCS #13: Elliptic Curve Cryptography Standard
- PKCS #15: Cryptographic Token Information Format Standard

?